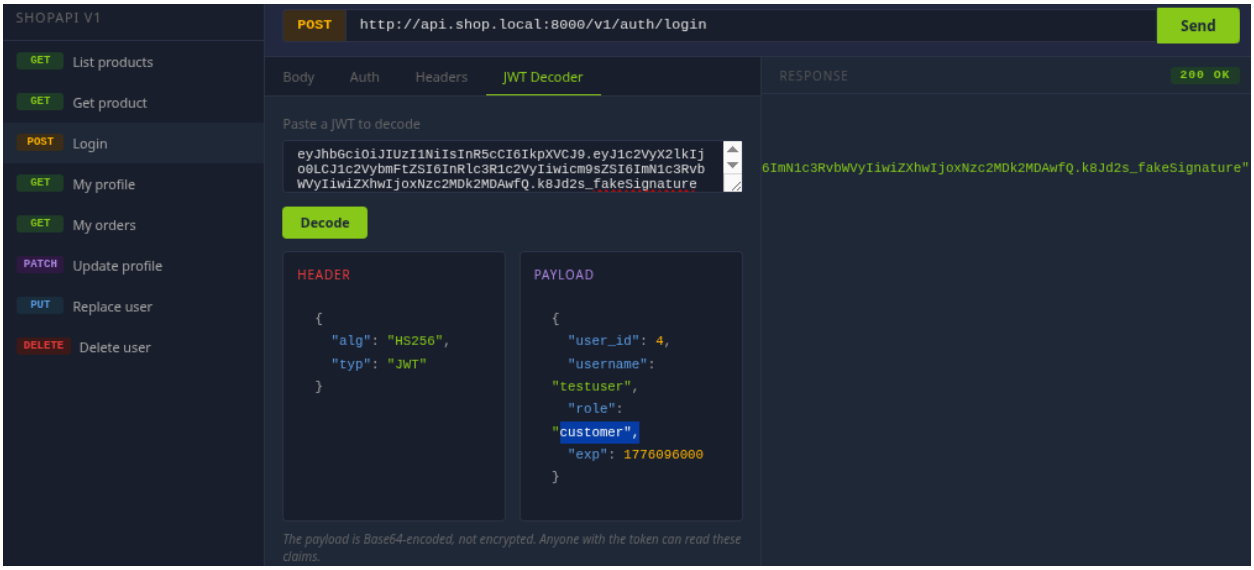
Jr.Pen 8.5. API Pentesting

Task 1 - Introduction

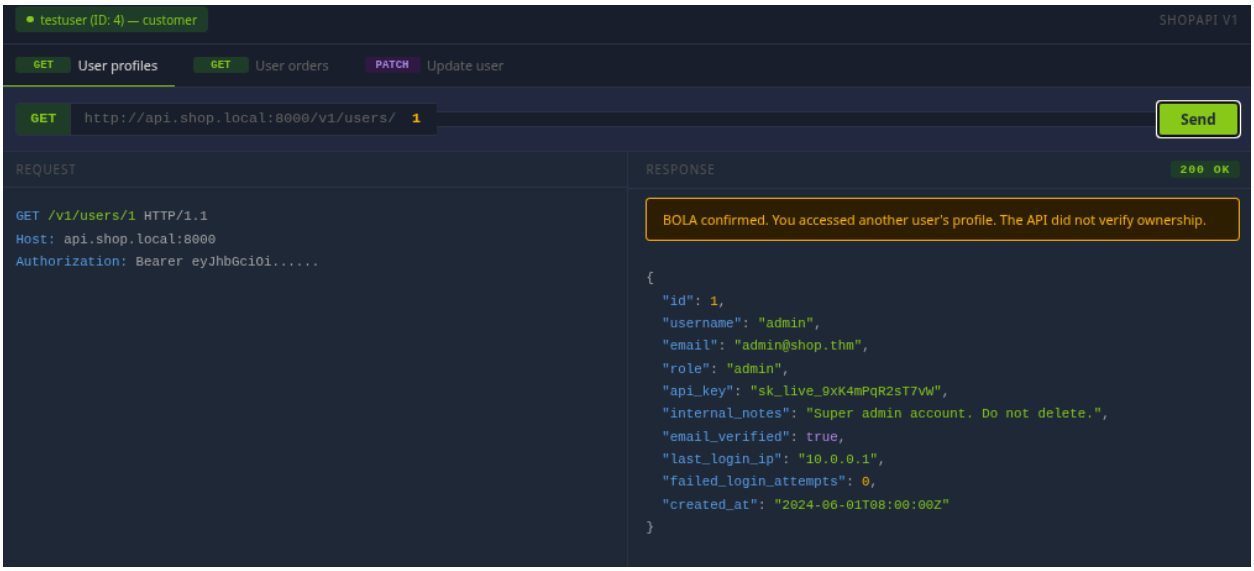
Task 2 - How REST APIs Work

Decode the JWT returned by the login endpoint. What role is assigned to the testuser account?

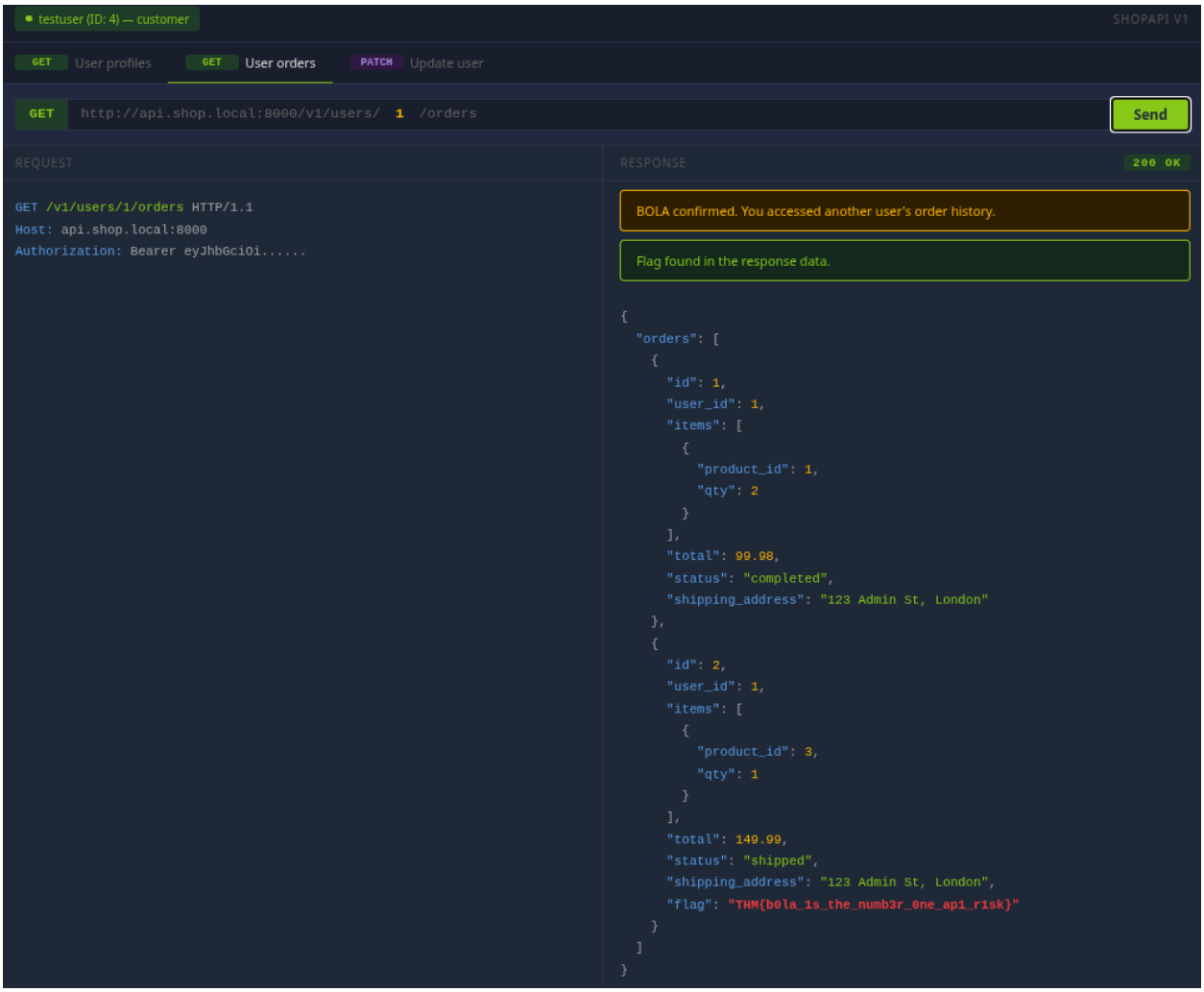


Task 3 - Broken Object Level Authorization (BOLA)

Access user 1's profile through the BOLA vulnerability. What is their email address?



Retrieve user 1's order history. What is the flag contained in one of their orders?



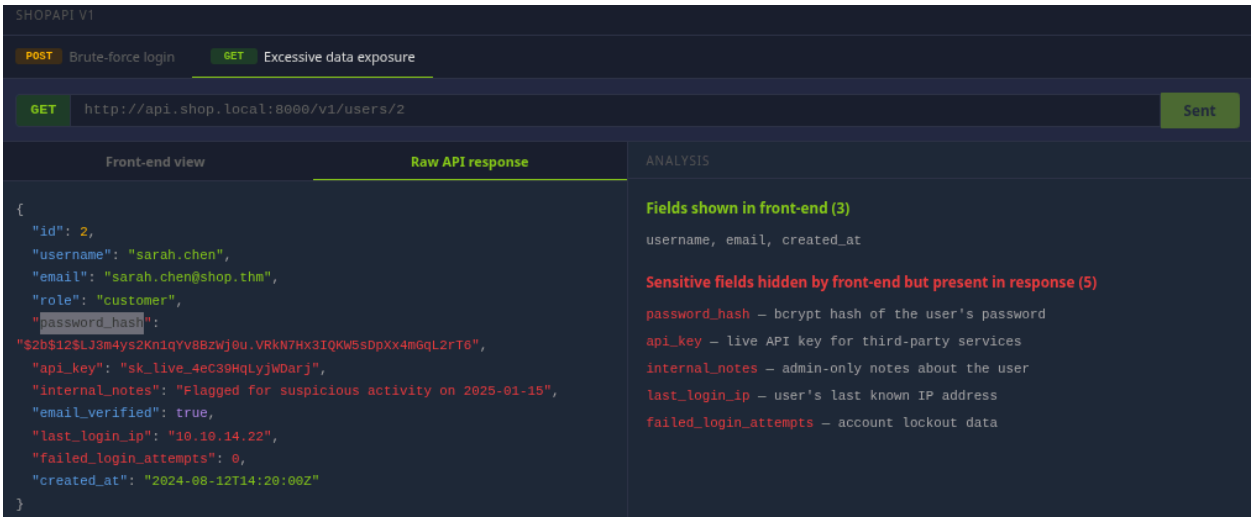
> What HTTP status code indicates that rate limiting is in effect?

429

> What password did you discover for the admin account?

sunshine

> In the raw API response for sarah.chen, what sensitive field contains a bcrypt hash?



> What information is revealed in the `internal_notes` field of sarah.chen's profile?

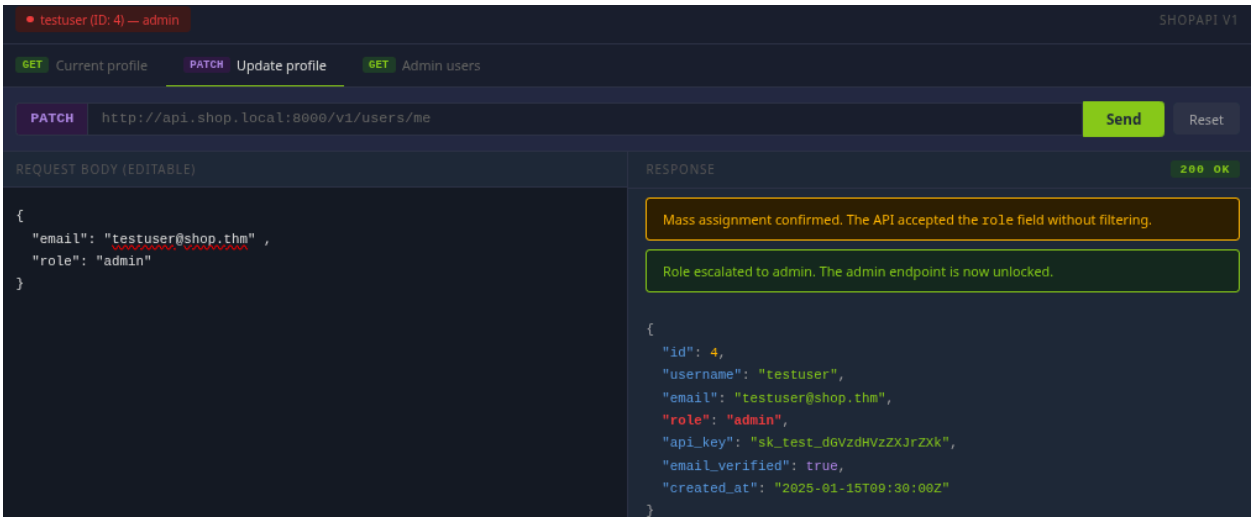
Task 4 - Broken Authentication and Excessive Data Exposure

> What is the term for the developer practice of applying all client-supplied fields directly to a data model without filtering?

mass assignment

> After adding `"role": "admin"` to the PATCH request, what is your new role?

Admin



> Using your escalated privileges, access the admin users endpoint. How many total users are registered on the platform?

7

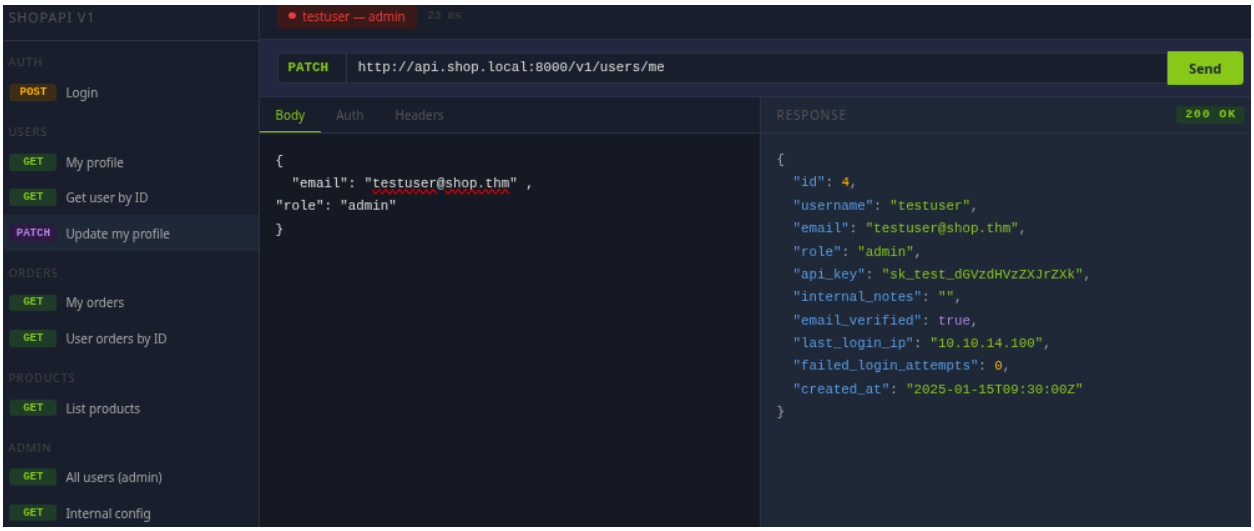
> What is the flag returned by the admin endpoint?



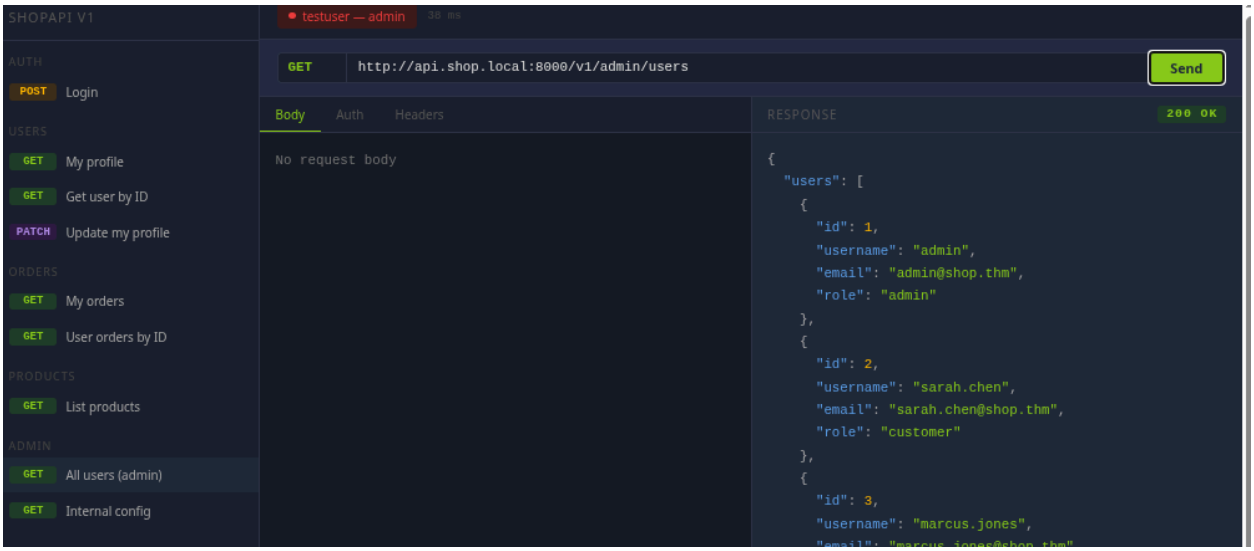
Task 5 - Mass Assignment and Rate Limiting

Task 6 - Putting It All Together

Add role as admin in update my profile section



Then click run all user



Task 7 - Conclusion